

PROJECT SESSION REPORT

티켓 예매 서비스 인프라 구축 및 검증 작업 정리

2026년 7월 6일, VM 인프라 구축부터 부하테스트·DB 복제·실시간 이상탐지·
자체 모의해킹까지 하루 동안 진행한 전체 작업을 정리한다.

대상 서비스 한강 이글스 티켓 예매 · 환경 VMware Fusion, 172.16.60.0/24 · 작성자 최시은

1. 오늘 진행 개요

VM 8대로 구성된 트래픽 대응 티켓 예매 인프라를 처음부터 구축하고, 좌석 동시성 제어·트래픽 폭증 대응·DB 복제·실시간 이상탐지가 실제로 동작하는지 K6·Suricata·nmap·Nikto로 직접 검증했다. 설계 문서에만 있던 내용을 전부 실제 환경에서 재현하고 수치로 확인하는 것을 목표로 했다.

영역	완료 내용
인프라 구축	bastion, db-01(+replica), redis, was-01/02, queue-gate, web-lb — 총 8대
배포	예매 웹페이지를 web-lb에 실제 배포, 브라우저 접속 확인
검증	동시성 제어(3회), 트래픽 폭증 대응, 로드밸런싱, DB 실시간 복제
탐지	Suricata 실시간 이상탐지 (queue-gate)
모의해킹	nmap 포트 검증, Nikto 웹 취약점 스캔 및 일부 조치

2. 서버 구성도

TICKET BOOKING INFRASTRUCTURE - 172.16.60.0/24

ADMIN PATH

SSH 키 인증 · Bastion 단일 진입점 경유



맥북
관리자 PC



SSH · 22
키 인증



bastion
.142



ProxyJump
경유



was-01/02
.145 / .151



db-01(+replica)
.143 / .148



redis
.144



queue-gate
.146



web-lb
.147

일반 유저는 이 경로에 접근 불가 - 22번 포트는 bastion IP에서만 허용 - - - - -

USER PATH

HTTPS · 예매 페이지를 통한 서비스 이용



브라우저
예매/로그인



80/443



queue-gate

.146
+Suricata



Rate limit
통과 후



web-lb

.147



3000
least_conn



was-01/02

.145 / .151



6379/3306



redis

.144



db-01

.143

DWG NO.

SESSION-0706

SCALE

NOT TO SCALE

DRAWN BY

최시은

REV

Final · 2026.07.06

3. 접속 경로 상세

3.1 관리자 접속 경로

```
맥북 (~/.ssh/ticket-project 개인키)
└─ ssh -i ~/.ssh/ticket-project bastion@172.16.60.142
    └─ ProxyJump 경유
        ├── was-01 (172.16.60.145)
        ├── was-02 (172.16.60.151)
        ├── db-01 (172.16.60.143) / db-01-replica (172.16.60.148)
        ├── redis (172.16.60.144)
        ├── queue-gate (172.16.60.146)
        └─ web-lb (172.16.60.147)
```

모든 서버는 **bastion IP(172.16.60.142)에서 오는 22번 포트만** ufw로 허용한다. 관리자 PC(맥북)조차 bastion을 거치지 않고는 어떤 내부 서버에도 SSH 접근이 불가능하다.

3.2 일반 사용자 접속 경로

```
사용자 브라우저
└─ http://172.16.60.146 (queue-gate, 80번 포트만 공개)
    └─ Rate limiting(초당 10건) 통과
        └─ web-lb (172.16.60.147, least_conn 로드밸런싱)
            ├── was-01 (172.16.60.145)
            └─ was-02 (172.16.60.151)
                ├── redis (좌석 원자연산)
                └─ db-01 → db-01-replica (실시간 복제)
```

사용자는 **queue-gate의 80번 포트 외에는 어떤 내부 서버에도 직접 접근할 수 없다**. was-01/02, redis, db-01은 각각 web-lb·was 서버발 요청만 허용하도록 ufw로 잠겨 있다.

오늘 nmap으로 실제 검증됨 — 외부(맥북)에서 was-01·web-lb를 스캔한 결과 전 포트가 filtered로 나왔고, queue-gate만 80번이 open으로 나와 설계한 접근 경로가 실제로 지켜지고 있음을 확인했다 (5장 참고).

4. 오늘 완료한 작업 체크리스트

- ✓ bastion — SSH 키 인증 전환, 비밀번호 로그인 차단, ufw 화이트리스트
- ✓ db-01 — MariaDB 설치, bind-address 고정, was_writer 계정(최소권한) 생성
- ✓ redis — bind/requirepass 설정, ufw 적용
- ✓ was-01 — Node.js 설치, 좌석 예약 API(Redis SETNX 원자연산) 구현
- ✓ queue-gate — Nginx 대기열/Rate limiting 설정
- ✓ web-lb — Nginx 로드밸런서 + 정적 웹페이지 서빙 설정, 실제 배포
- ✓ was-02 — 추가 구축, 로드밸런싱 분산 확인(was-01/02 교차 응답)
- ✓ db-01-replica — mysqldump 복원, 복제 연결, 실시간 동기화 검증
- ✓ Suricata — queue-gate에 설치, 예약 API 이상탐지 룰 구성 및 실전 탐지 확인
- ✓ nmap/Nikto — 포트 검증 및 웹 취약점 스캔, 보안헤더 3종 조치

5. 핵심 검증 결과

5.1 좌석 등시성 제어 (시나리오 3)

테스트	방식	결과
순차 curl 2회	같은 좌석에 연속 요청	1회 성공, 1회 거부(409)
K6 (was-01 내부)	VU 100, 동일 좌석 동시 요청	DB에 정확히 1건만 저장
K6 (k6-runner 외부)	네트워크 경유 VU 100 동시 요청	DB에 정확히 1건만 저장

Redis SETNX 원자연산이 3가지 조건(순차/내부/외부 네트워크)에서 모두 중복예약을 막는 것을 확인했다.

5.2 트래픽 폭증 대응 (시나리오 2, 대기열 **ON/OFF** 비교)

지표	대기열 OFF	대기열 ON	해석
checks_failed	1.27%	0.00%	대기열 ON일 때 완전 무응답 요청 없음
http_req_duration max	60,000ms	108.8ms	대기열이 최악의 지연을 방지
처리량	91,801건	864,696건	초과 요청을 즉시 429로 처리해 처리효율 유지

대기열은 요청을 "느리게 처리"하는 게 아니라 "감당 가능한 양만 받고 초과분은 즉시 거절"하는 방식으로 서버 가용성을 지킨다는 것을 실측으로 확인했다.

5.3 DB 복제 (Primary-Replica)

단계	결과
초기 복제 연결	Slave_SQL_Running: No — 이전 DROP USER 명령이 binlog에 남아 에러 발생
문제 해결	sql_slave_skip_counter=1로 문제 이벤트 스킵 후 재개
최종 확인	Slave_IO/SQL_Running: Yes,Seconds_Behind_Master: 0
실시간 복제 검증	Primary에 INSERT한 데이터가 즉시 Replica에 반영됨을 확인

5.4 Suricata 실시간 이상탐지

최초 monitor를 별도 서버(트래픽 경로 밖)에 배치했으나 패킷을 관찰할 수 없어 탐지 실패. **실제 트래픽이 지나가는 queue-gate에 Suricata를 직접 설치**하는 구조로 전환 후, K6 공격 시뮬레이션(VU 10, 15초간 반복 요청)을 실행하자 Excessive booking API calls detected 알림이 실시간으로 발생함을 확인했다.

IDS는 "무엇을 탐지하느냐"보다 "어디에 배치하느냐"가 먼저라는 것을 실습으로 확인한 지점이다.

6. 자체 모의해킹 결과

6.1 nmap 포트 스캔 (외부/맥북 관점)

서버	22	80	443	3000	3306/6379
queue-gate (.146)	filtered	open	closed	filtered	filtered
web-lb (.147)	filtered	filtered	filtered	filtered	filtered
was-01 (.145)	filtered	filtered	filtered	filtered	filtered

설계 문서의 포트 매트릭스와 실제 스캔 결과가 정확히 일치했다. queue-gate만 80번이 열려 있고, web-lb·was-01은 허용되지 않은 출발지(맥북)에게 모든 포트가 filtered로 관측되어 최소권한 방화벽 정책이 실제로 작동함을 증명했다. 443이 closed로 나온 것은 TLS 인증서 미설정 때문이며 향후 개선점으로 남긴다.

6.2 Nikto 웹 취약점 스캔 (queue-gate 대상)

항목	1차	2차(조치 후)	심각도
Strict-Transport-Security 누락	미적용	미적용	Medium
X-Content-Type-Options 누락	미적용	미적용	Medium
Content-Security-Policy 누락	미적용	적용됨	해결
Referrer-Policy 누락	미적용	적용됨	해결
Permissions-Policy 누락	미적용	적용됨	해결

Nikto가 함께 보고한 Cisco/Vignette/FrontPage 관련 다수 항목은 범용 취약점 DB를 기계적으로 대조한 오탐(false positive)으로 판단하여 제외했다 — 현재 스택(Nginx 정적 서빙 + Node API)과 무관한 항목들이다.

남은 조치 — HSTS, X-Content-Type-Options 헤더 2개는 아직 미적용 상태로, 다음 세션에서 Nginx 설정에 추가하고 3차 재검증이 필요하다.

6.3 보류한 항목

항목	보류 사유
Hydra 인증 무차별 대입 테스트	로그인 API가 아직 백엔드에 구현되지 않아 테스트 대상 부재
sqlmap SQLi 테스트	파라미터 기반 GET 엔드포인트가 많지 않아 유의미한 테스트 어려움

7. 트러블슈팅 노트

문제	원인	해결
vi 편집 중 화살표 키로 텍스트 오염	터미널 vi가 화살표 키(ESC 시퀀스)를 인식 못해 명령으로 오작동	vi 대신 sed/heredoc(cat << EOF)으로 전환
SSH ProxyJump 시 Permission denied	ProxyJump 대상 Host에 IdentityFile 미지정	SSH config에 각 서버별 Host 등록, IdentityFile 명시
mysql_secure_installation not found	최신 MariaDB는 mariadb-secure-installation으로 개명	새 명령어명으로 실행
was_writer 계정 Access denied	계정이 172.16.60.% 원격 전용인데 localhost로 접속 시도	-h 옵션으로 실제 IP 지정
Nginx 배포 후 기본 페이지만 표시	sites-enabled/default가 우리 설정보다 우선 적용	기본 심볼릭 링크 삭제
mysqldump 결과 테이블 없음	was_writer에 LOCK TABLES 권한 부족	--single-transaction --skip-lock-tables 옵션 사용
복제 연결 후 SQL_Running: No	계정 재생성 과정의 DROP USER가 binlog에 남아 replica에서 재생 실패	sql_slave_skip_counter=1로 문제 이벤트 스킵
Suricata 서비스 실패	설정 파일에 eth0(실제는 ens160), KiB 단위 오류	인터페이스명·단위 표기 수정
Suricata 로딩 실패	content가 http.uri보다 먼저 와 sticky buffer 매치 안 됨	키워드 순서 수정(http.uri 먼저)
monitor 서버가 공격 트래픽 미탐지	실제 트래픽 경로 밖에 배치되어 패킷을 볼 수 없음	트래픽이 실제로 지나가는 queue-gate에 재설치

8. 다음 단계

- ✓ Nginx 보안헤더 2개(HSTS, X-Content-Type-Options) 마저 적용 후 Nikto 3차 재검증
- ✓ 회원가입/로그인 API를 실제 백엔드에 구현 → Hydra 인증공격 테스트 가능하게
- ✓ TLS 인증서 적용 (Let's Encrypt 또는 Cloudflare Origin) → 443 open 전환
- ✓ ELK 연동으로 Suricata 로그 시각화 (선택)
- ✓ 오늘 결과를 근거로 부하테스트·모의해킹 결과 보고서 세부 문서화
- ✓ GitHub 리포지토리 정리 및 README 작성

본 문서는 2026년 7월 6일 진행한 작업 세션을 정리한 기록이며, 표기된 IP/포트/설정값은 학습용 환경(172.16.60.0/24) 기준이다.